Regression Test Report

SRM PRIME Approval System — pre-release regression of the production build

Date	14 Oct 2026
Build under test	Git `9569a5a` (tests added) plus the access-control fix described in section 2
Environment	Isolated local stack: FastAPI + disposable PostgreSQL 16 (Docker, port 55432) + Vite dev server, Chromium (Playwright). **No production system, data or credentials were touched.**
Tools	pytest 9 (backend), Playwright (browser E2E + API), Vite build, ESLint

1. Summary

157/157	59/59	1 fixed	Pass
Backend tests passed	Browser/E2E tests passed	Security defect found & fixed	Build & lint

Verdict: no regressions found in existing functionality. One pre-existing authorization defect was found by the new tests and **fixed in this change** (section 2); it is now guarded by a backend test and a browser test. Release recommendation: ready.

Check	Result
Backend suite (pytest, real DB, migrations applied & rolled back)	157 passed, 0 failed, 0 skipped in 43s
Browser E2E (Playwright, Chromium)	59 of 59 behaved as expected (0 unexpected failures, 0 flaky)
Frontend production build (`vite build`)	Success
Frontend lint (`eslint .`)	0 errors, 1 pre-existing warning (react-hooks/incompatible-library)

2. Defect found and fixed: requester could advance their own request through approval stages

> **Severity: High (approval-integrity). Status: FIXED.**
> **Before:** a REQUESTER could call `PATCH /requests/{id}` with `action=forwarded` on their own request and the stage advanced with no approver involved (observed: INSTITUTION_MANAGER → HEAD_OF_INSTITUTION → CHAIRMAN_OFFICE, HTTP 200 each time). Present since the initial commit. Cause: the owner is always allowed to "act" (`access.py::can_act_on_request`) and the forward branch of `service.py::update_request` never checked that the caller held the current stage.
> **Fix:** `backend/app/requests/service.py` — a `forwarded` action now requires `is_stage_holder(user, request)` , else HTTP 403. Owners keep the ability to attach files and reject/withdraw. The check runs before any side effects (file storage, history).
> **Verification:** new backend test `test_requester_cannot_forward_their_own_request_past_approvers` and browser test **REQ-06** (403 and stage still INSTITUTION_MANAGER); the pre-existing forwarding tests (IM, accountant routing, HOI-created and IM-created requests) still pass. Backend 157/157, browser 59/59.
> **Related observation (not changed):** SOP and budget fields on a request can be set by any actor allowed to act (code comment says this matches the original system). Consider restricting them to the Institution Manager / Accountant respectively.

3. Backend regression results (pytest)

Run against a disposable PostgreSQL test database; Alembic migrations are applied before and rolled back after the run.

Area	Tests	Passed
auth	17	17
completed	5	5
email	14	14
files	9	9
flagged	3	3
form_configs	3	3
policies	4	4
queries	11	11
requests	36	36
sops	16	16
tasks	11	11
test_frontend_contract	6	6
test_hardening	6	6
test_health	1	1
test_smoke	1	1
test_trusted_proxy	7	7
users	7	7
Total	**157**	**157**

Test maintenance performed during this run

The first run showed 3 failures. None was a product regression; all were stale/non-isolated tests, fixed in the test code only (no production code changed):

Test	Root cause	Fix
`test_hardening::test_oversized_json_body_is_rejected`	Commit `f0b910a` intentionally raised the JSON body cap from 200 KB to 10 MB; the test still sent 250 KB.	Test now sends 11 MB.
`email/test_health` (2 tests)	Depended on real SMTP credentials being present in the developer's environment.	Tests now set their own credentials.

4. Browser & API end-to-end results (Playwright)

Seeded one user per role (`app.scripts.seed_users`) in a fresh database, real login through the UI, real API calls.

Area	Tests	As expected
Authentication & platform API	14	14
Navigation & role-based access (RBAC)	22	22
Request lifecycle & Create Request form	14	14
Profile, content pages & error handling	9	9
Total	**59**	**59**

Complete list

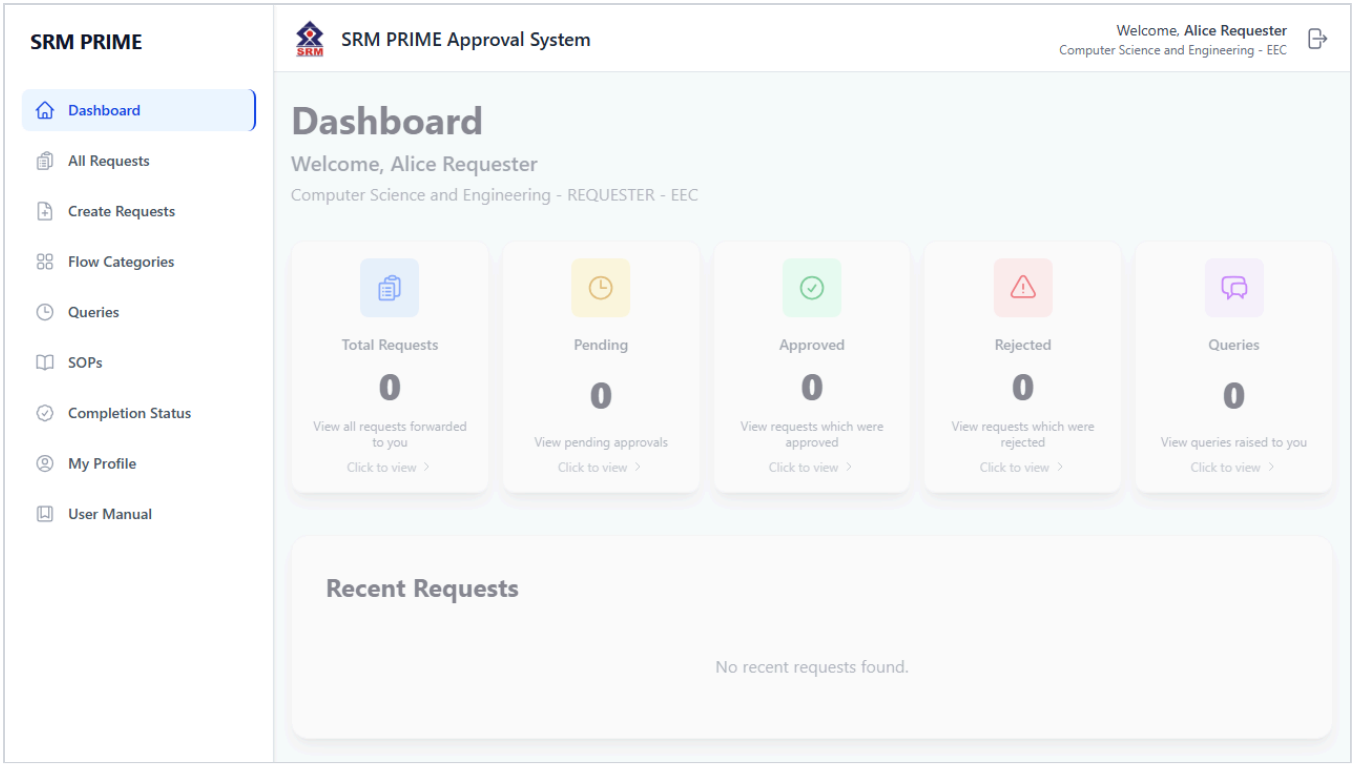
Area	Test	Result	Time
Authentication & platform API	AUTH-01 login page renders	PASS	2.2s
Authentication & platform API	AUTH-02 valid login by email lands on the dashboard	PASS	1.5s
Authentication & platform API	AUTH-03 valid login by employee ID	PASS	1.1s
Authentication & platform API	AUTH-04 wrong password shows an error and stays on login	PASS	1.2s
Authentication & platform API	AUTH-05 protected pages redirect anonymous visitors to login	PASS	2.1s
Authentication & platform API	AUTH-06 session survives a page reload (refresh cookie)	PASS	1.6s
Authentication & platform API	AUTH-07 logout ends the session	PASS	1.5s
Authentication & platform API	AUTH-08 forgot-password page is reachable from login	PASS	0.8s
Authentication & platform API	AUTH-09 already signed-in user visiting /login is sent to dashboard	PASS	1.6s
Authentication & platform API	API-01 /ping is public and returns 200	PASS	0.0s
Authentication & platform API	API-02 protected endpoints reject missing tokens with 401	PASS	0.0s
Authentication & platform API	API-03 login returns an access token and sets an httpOnly refresh cookie	PASS	0.1s
Authentication & platform API	API-04 security headers are present	PASS	0.0s
Authentication & platform API	API-05 JSON body over the 10MB cap is rejected with 413	PASS	0.1s
Navigation & role-based access (RBAC)	RBAC-NAV REQUESTER: sidebar shows only permitted entries	PASS	1.2s

Navigation & role-based access (RBAC)	RBAC-NAV INSTITUTION_MANAGER: sidebar shows only permitted entries	PASS	1.1s
Navigation & role-based access (RBAC)	RBAC-NAV HEAD_OF_INSTITUTION: sidebar shows only permitted entries	PASS	1.1s
Navigation & role-based access (RBAC)	RBAC-NAV DIRECTOR_ADMIN: sidebar shows only permitted entries	PASS	1.1s
Navigation & role-based access (RBAC)	RBAC-NAV CHAIRMAN: sidebar shows only permitted entries	PASS	1.1s
Navigation & role-based access (RBAC)	RBAC-NAV CHAIRMAN_OFFICE: sidebar shows only permitted entries	PASS	1.1s
Navigation & role-based access (RBAC)	PAGE REQUESTER can open /requests	PASS	1.3s
Navigation & role-based access (RBAC)	PAGE REQUESTER can open /create-request	PASS	1.5s
Navigation & role-based access (RBAC)	PAGE REQUESTER can open /flow-categories	PASS	1.5s
Navigation & role-based access (RBAC)	PAGE REQUESTER can open /queries	PASS	1.4s
Navigation & role-based access (RBAC)	PAGE REQUESTER can open /sops	PASS	1.4s
Navigation & role-based access (RBAC)	PAGE REQUESTER can open /completion-status	PASS	1.4s
Navigation & role-based access (RBAC)	PAGE REQUESTER can open /my-profile	PASS	1.4s
Navigation & role-based access (RBAC)	PAGE HEAD_OF_INSTITUTION can open /policies	PASS	1.3s
Navigation & role-based access (RBAC)	PAGE HEAD_OF_INSTITUTION can open /create-policy	PASS	1.5s
Navigation & role-based access (RBAC)	PAGE HEAD_OF_INSTITUTION can open /flagged	PASS	1.4s
Navigation & role-based access (RBAC)	PAGE HEAD_OF_INSTITUTION can open /user-management	PASS	1.4s
Navigation & role-based access (RBAC)	PAGE DIRECTOR_ADMIN can open /workflow	PASS	1.4s
Navigation & role-based access (RBAC)	PAGE CHAIRMAN_OFFICE can open /create-sop	PASS	1.4s
Navigation & role-based access (RBAC)	RBAC-GUARD requester opening Create Policy is denied	PASS	1.4s
Navigation & role-based access (RBAC)	RBAC-GUARD non chairman-office user opening Create SOP is denied	PASS	1.4s
Navigation & role-based access (RBAC)	RBAC-API requester cannot list users	PASS	0.1s
Request lifecycle & Create Request form	REQ-01 new request is created at the Institution Manager stage	PASS	0.2s
Request lifecycle & Create Request form	REQ-02 requester sees their request in All Requests and can open it	PASS	1.8s

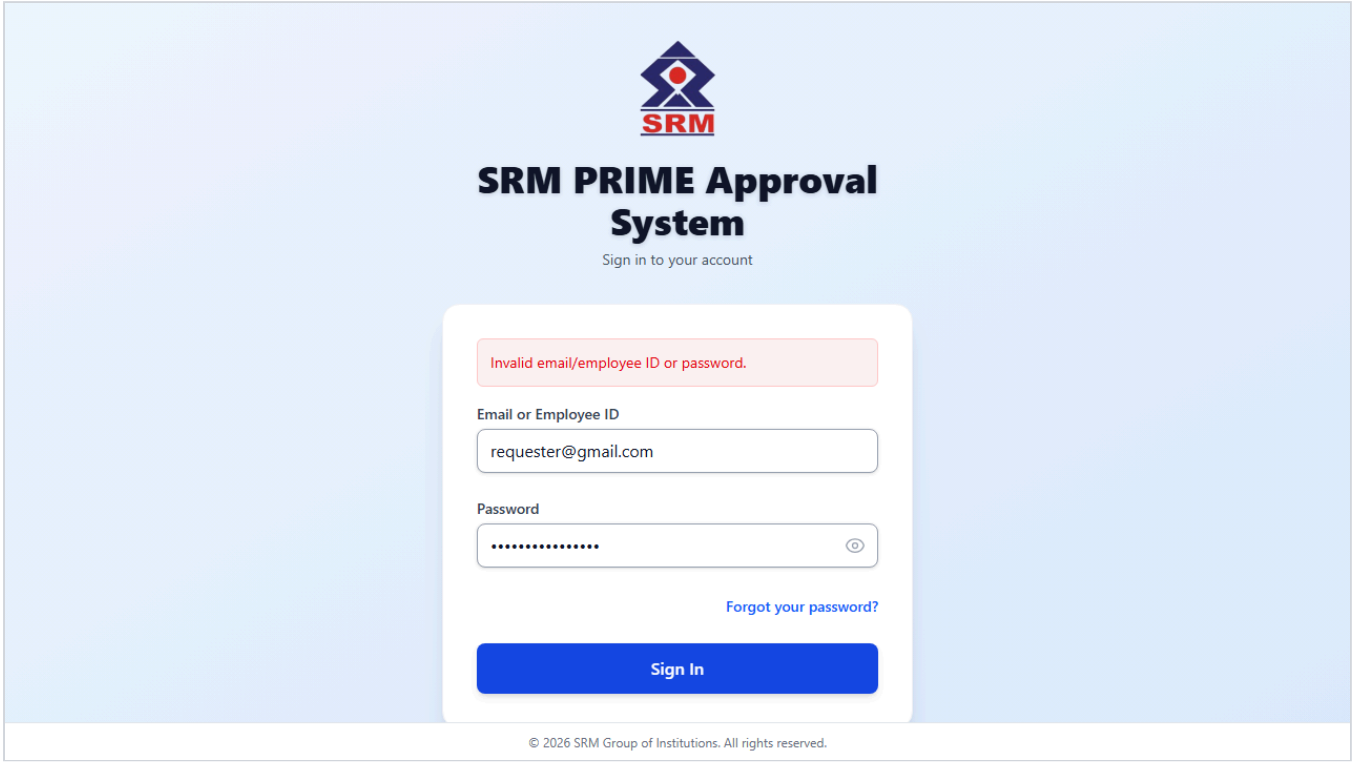
Request lifecycle & Create Request form	REQ-03 stage holder (Institution Manager) gets the Process Request action	PASS	1.6s
Request lifecycle & Create Request form	REQ-04 forwarding a zero-cost request skips the accountant (UI reflects new stage)	PASS	1.6s
Request lifecycle & Create Request form	REQ-05 forwarding a request with a cost estimate goes to the accountant	PASS	0.1s
Request lifecycle & Create Request form	REQ-06 the requester cannot forward their own request past the approvers	PASS	0.1s
Request lifecycle & Create Request form	REQ-07 a user at the wrong stage cannot forward (HOI cannot act at IM stage)	PASS	0.2s
Request lifecycle & Create Request form	REQ-08 rejecting a request moves it to REJECTED and the UI shows it	PASS	1.6s
Request lifecycle & Create Request form	REQ-09 request list filters: Pending / Rejected tabs respond	PASS	1.7s
Request lifecycle & Create Request form	REQ-10 request without an attachment is refused by the API	PASS	0.0s
Request lifecycle & Create Request form	FORM-01 submitting an empty form shows validation errors and does not navigate	PASS	1.6s
Request lifecycle & Create Request form	FORM-02 title shorter than 5 characters is flagged on blur	PASS	1.6s
Request lifecycle & Create Request form	FORM-03 picking a request type reveals its approval category	PASS	1.6s
Request lifecycle & Create Request form	FORM-04 requester submits an MOU request through the form and lands on its detail page	PASS	2.5s
Profile, content pages & error handling	MISC-01 My Profile shows the signed-in user's details	PASS	1.4s
Profile, content pages & error handling	MISC-02 /users/me matches the seeded account	PASS	0.1s
Profile, content pages & error handling	MISC-03 Flow Categories reference page lists categories	PASS	1.5s
Profile, content pages & error handling	MISC-04 Queries and Completion Status render empty states without errors	PASS	2.0s
Profile, content pages & error handling	MISC-05 Head of Institution user management lists users	PASS	1.5s
Profile, content pages & error handling	MISC-06 dashboard renders for every seeded approval role without JS errors	PASS	6.8s
Profile, content pages & error handling	MISC-07 unknown route does not crash the shell	PASS	1.8s
Profile, content pages & error handling	MISC-08 opening a non-existent request shows an error state, not a blank page	PASS	1.5s
Profile, content pages & error handling	MISC-09 mobile viewport collapses navigation into a drawer	PASS	1.0s

5. Evidence (screenshots captured at the end of each test)

AUTH-02 valid login by email lands on the dashboard — PASS

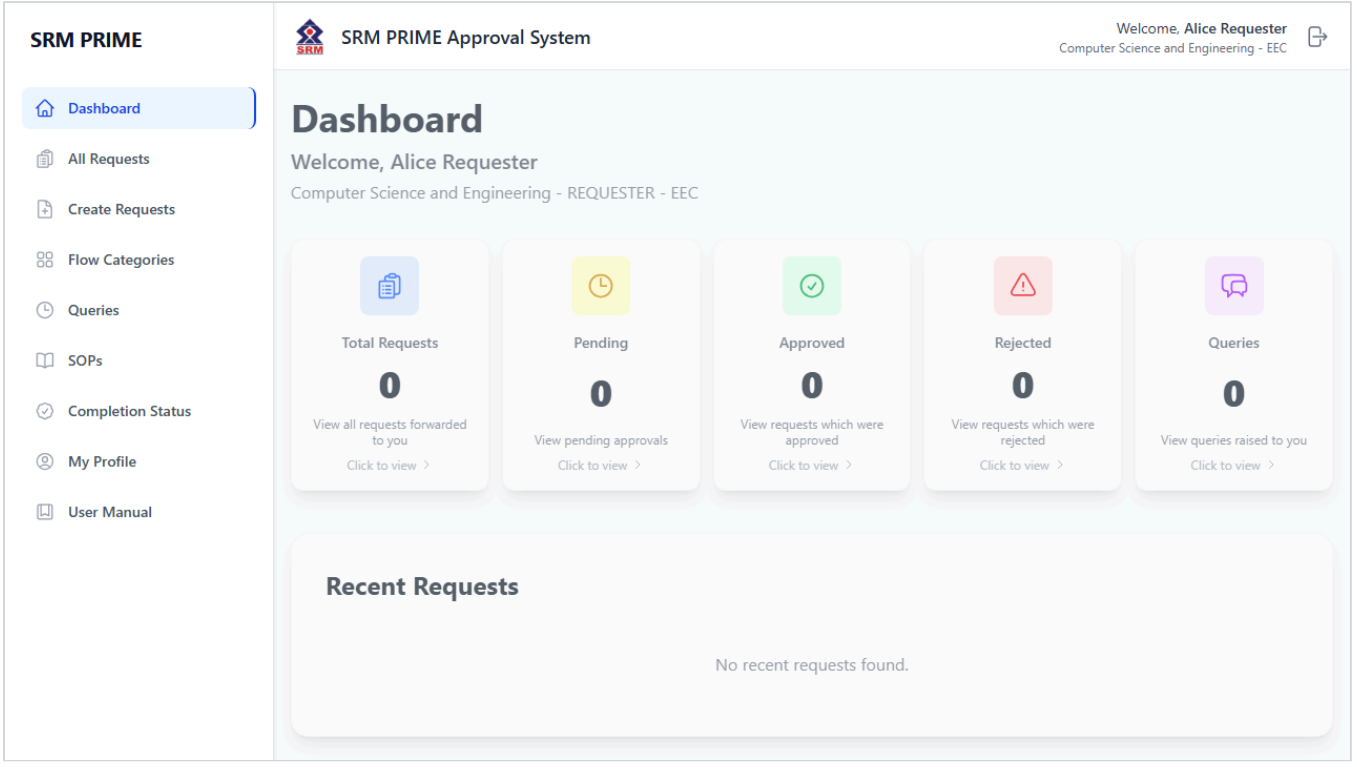


AUTH-04 wrong password shows an error and stays on login — PASS

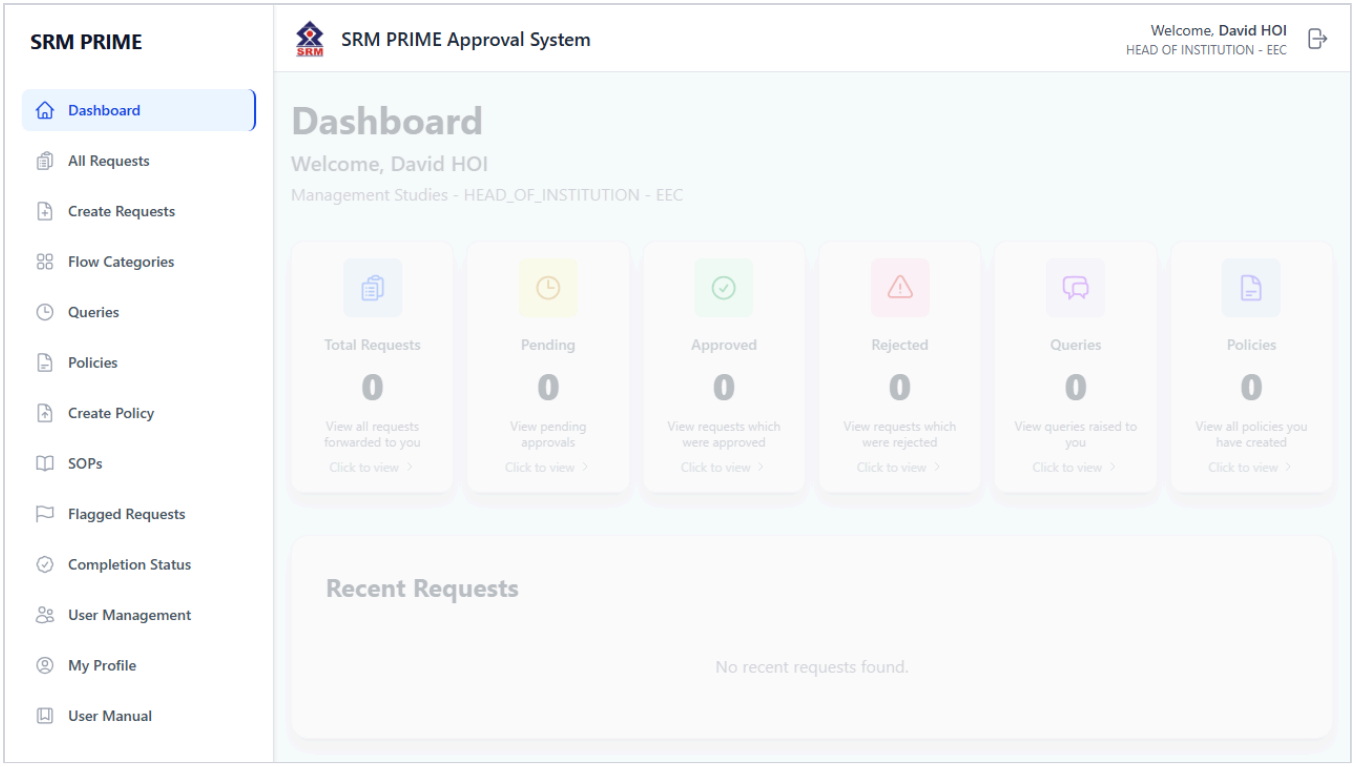


AUTH-05 protected pages redirect anonymous visitors to login — PASS

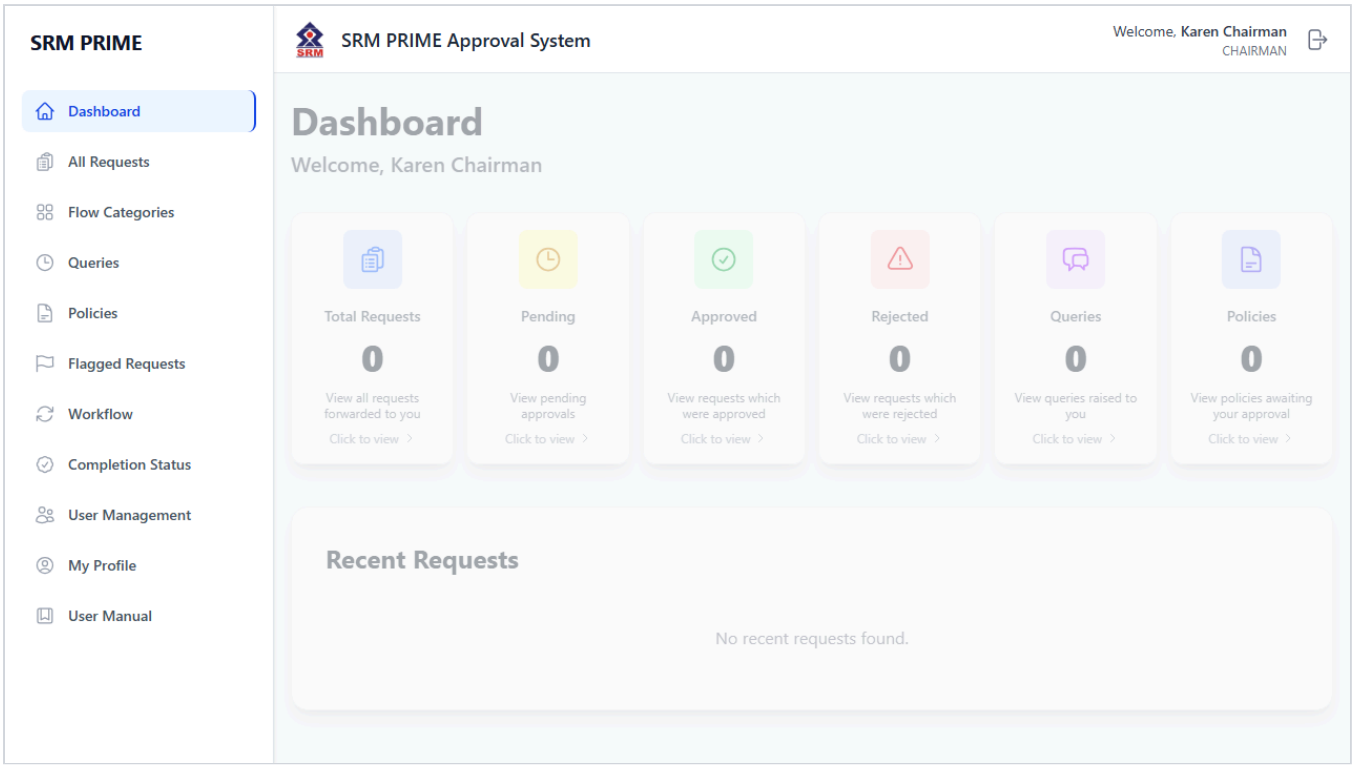
RBAC-NAV REQUESTER: sidebar shows only permitted entries — PASS



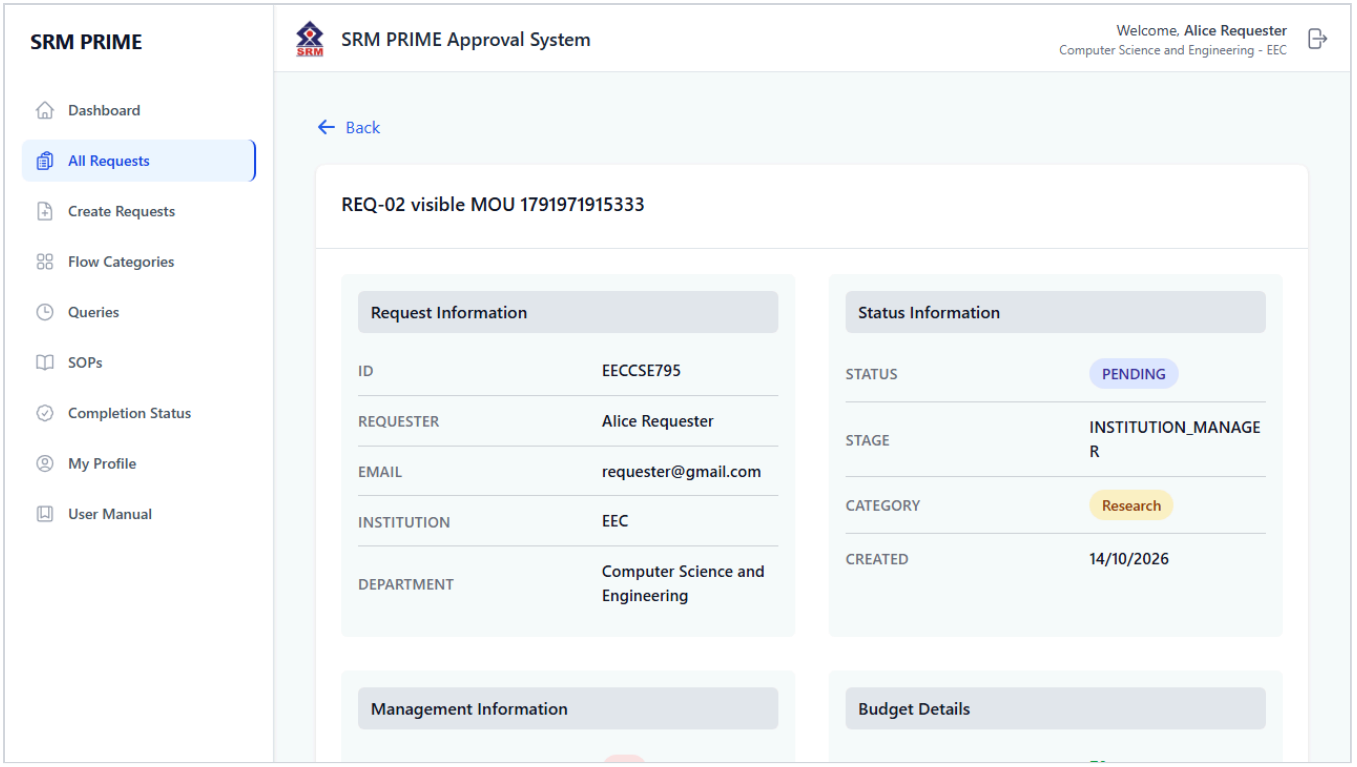
RBAC-NAV HEAD_OF_INSTITUTION: sidebar shows only permitted entries — PASS



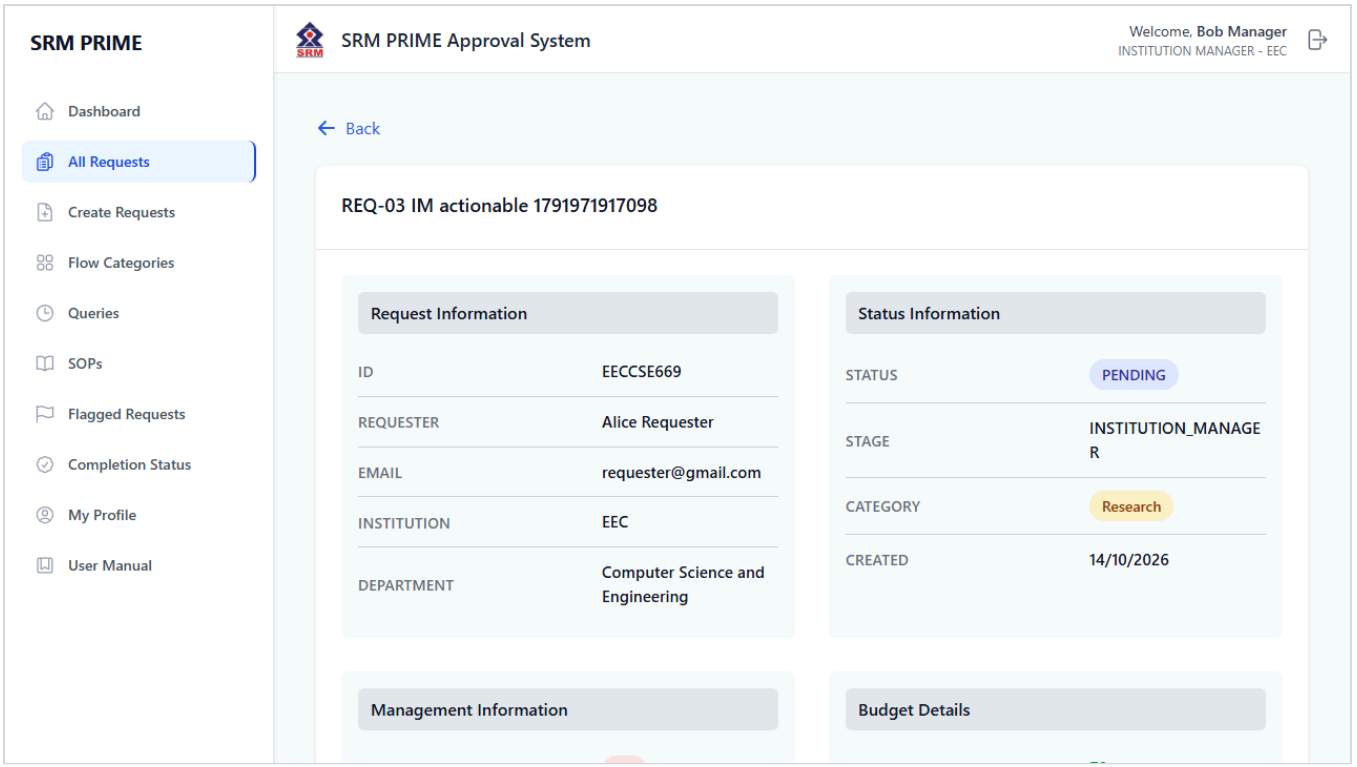
RBAC-NAV CHAIRMAN: sidebar shows only permitted entries — PASS



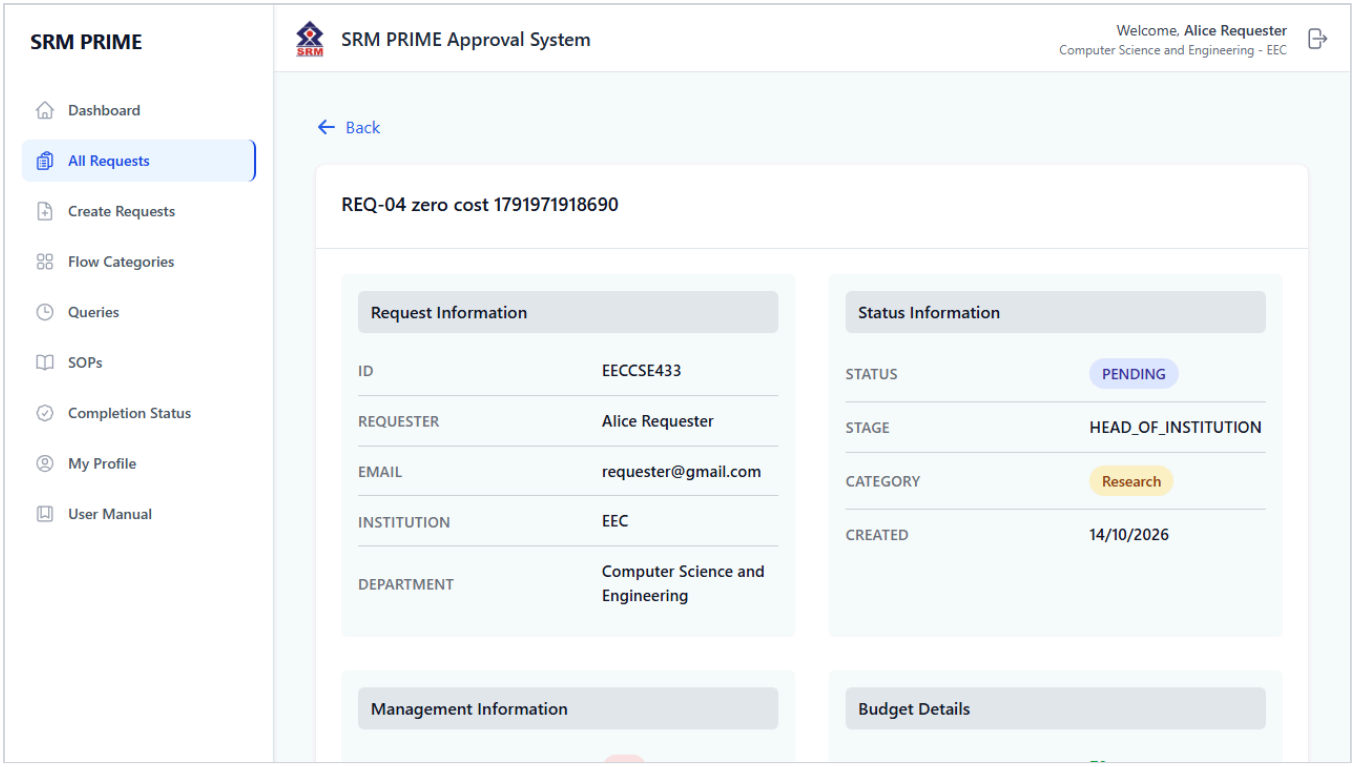
REQ-02 requester sees their request in All Requests and can open it — PASS



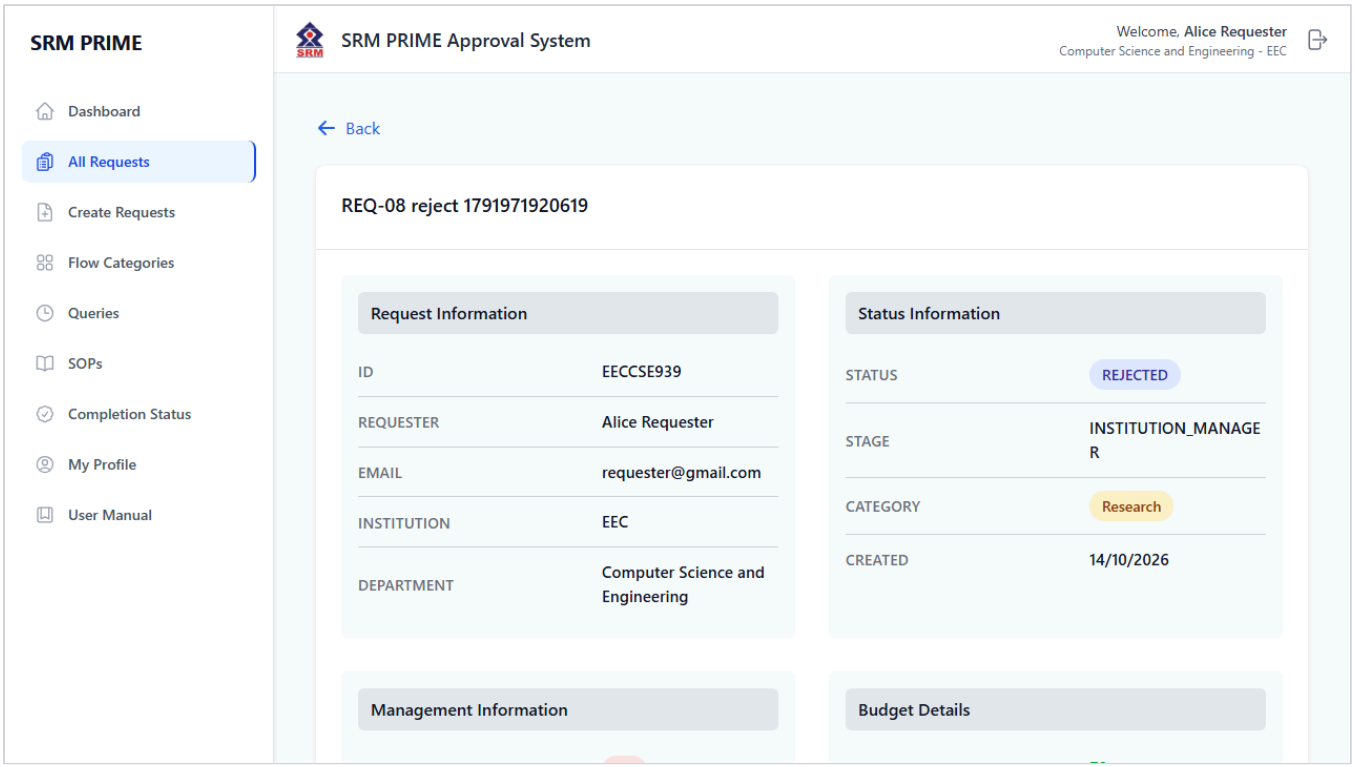
REQ-03 stage holder (Institution Manager) gets the Process Request action — PASS



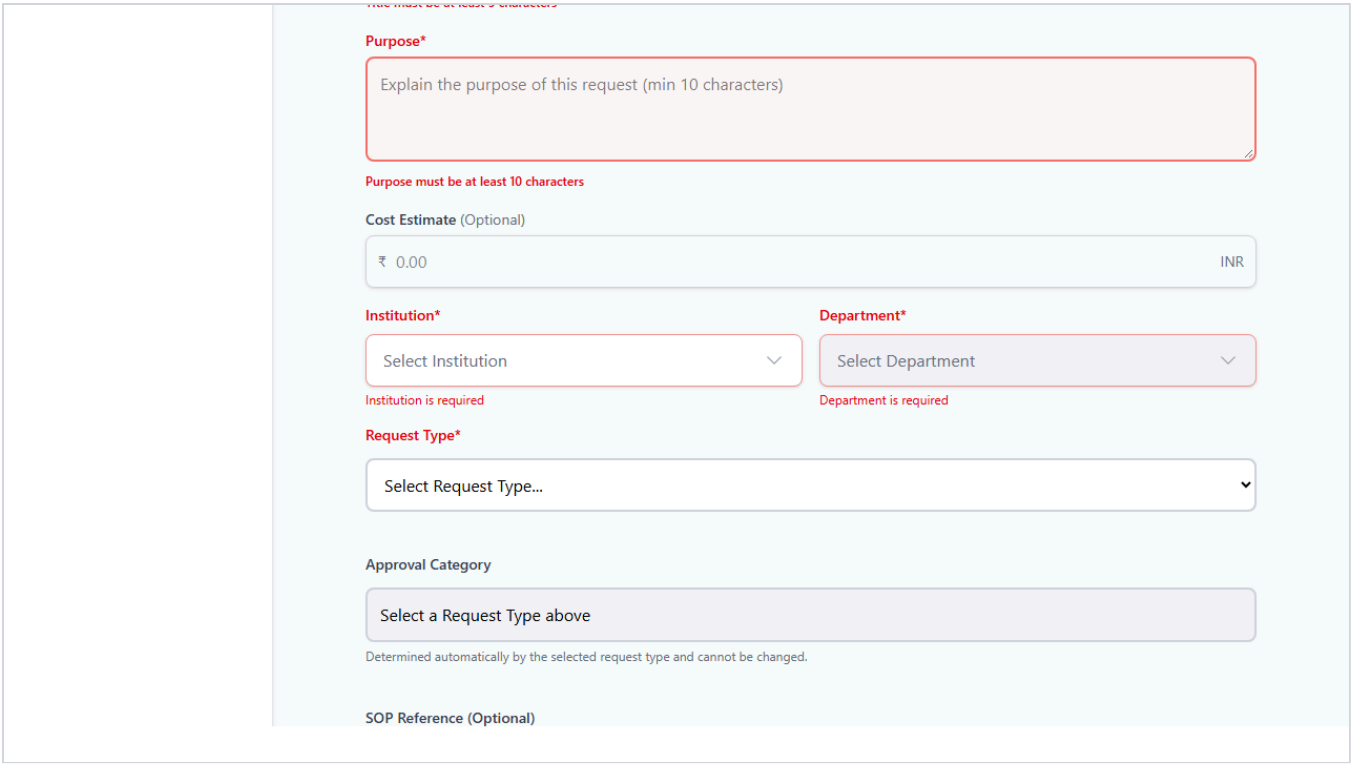
REQ-04 forwarding a zero-cost request skips the accountant (UI reflects new stage) — PASS



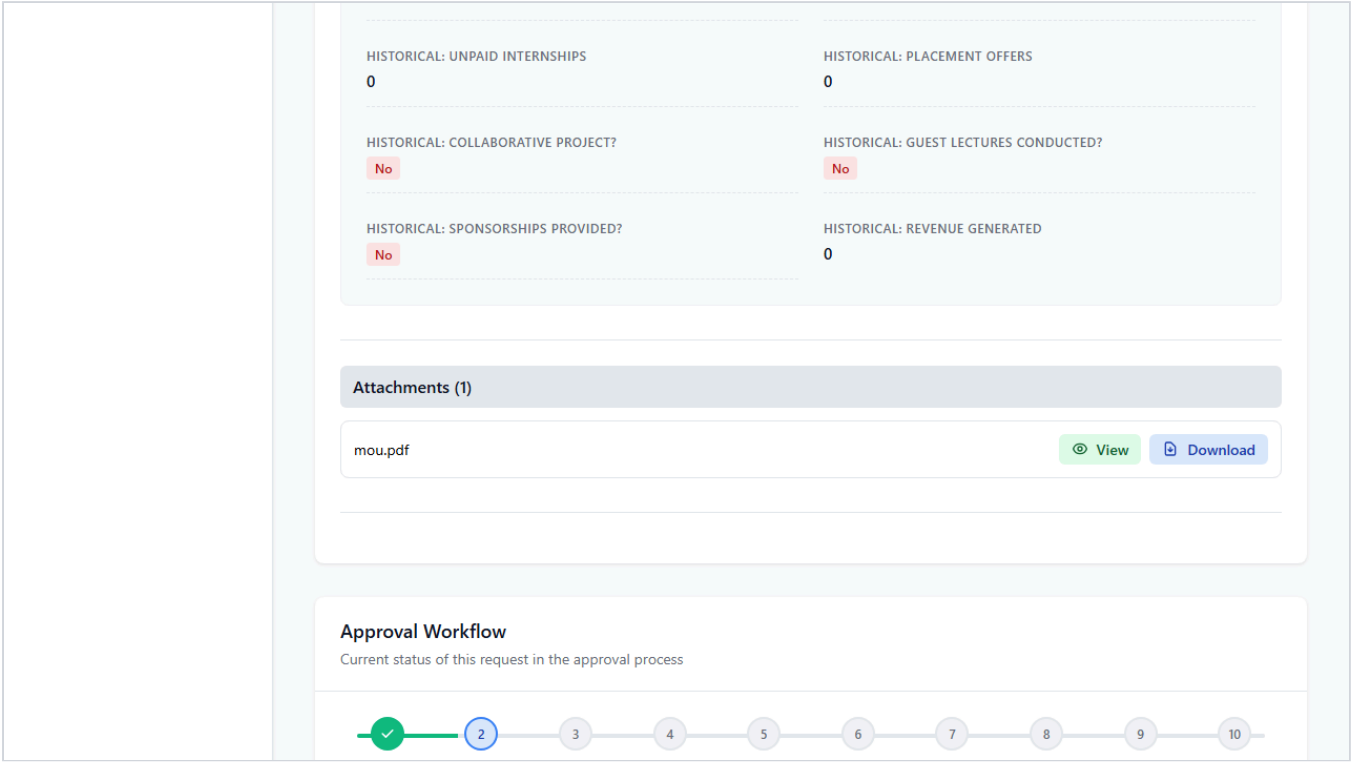
REQ-08 rejecting a request moves it to REJECTED and the UI shows it — PASS



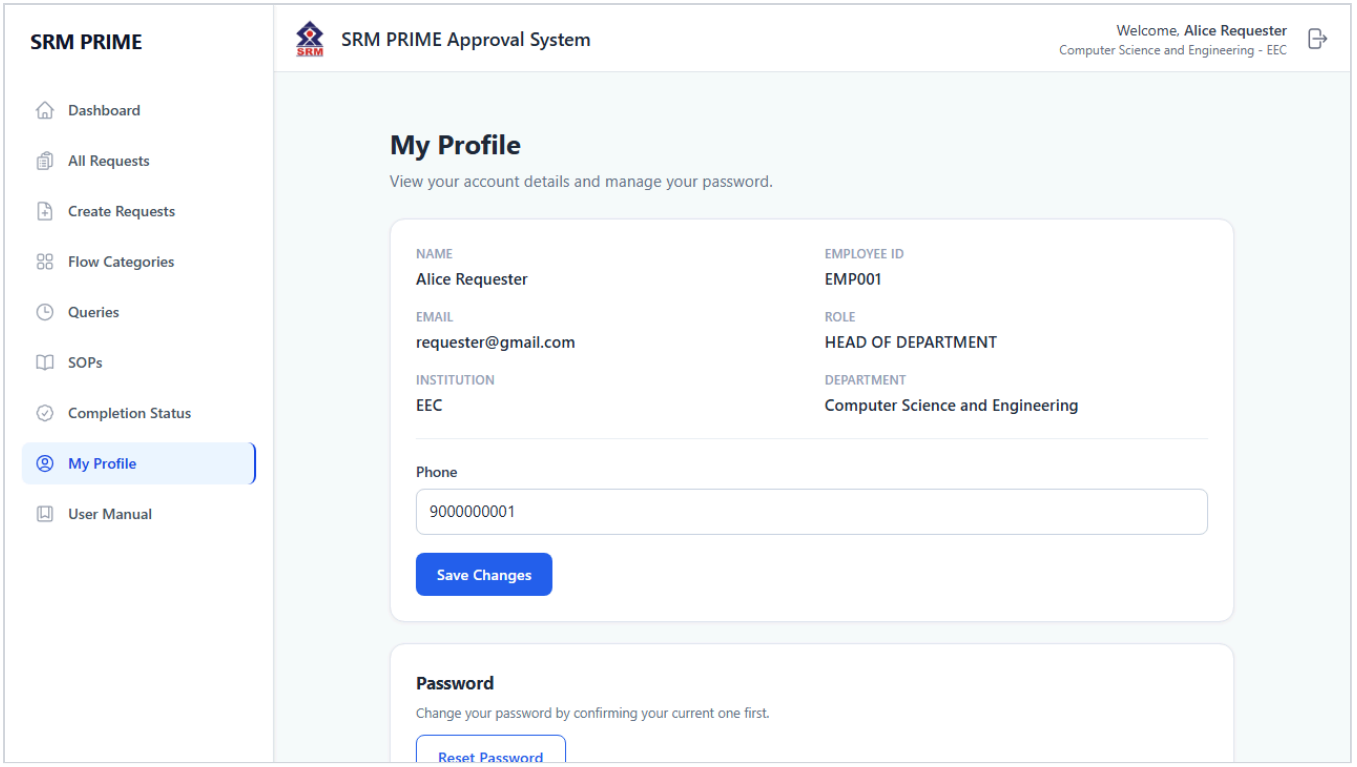
FORM-01 submitting an empty form shows validation errors and does not navigate — PASS



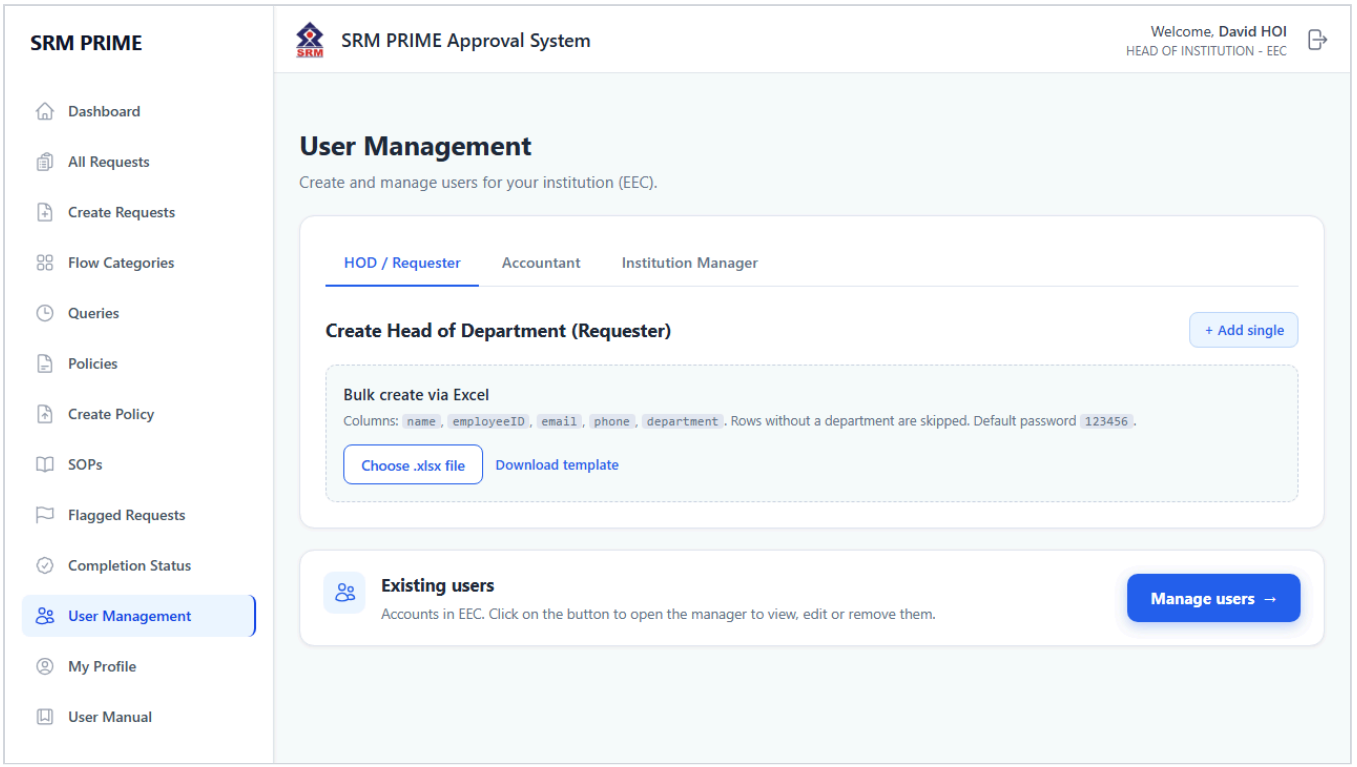
FORM-04 requester submits an MOU request through the form and lands on its detail page — PASS



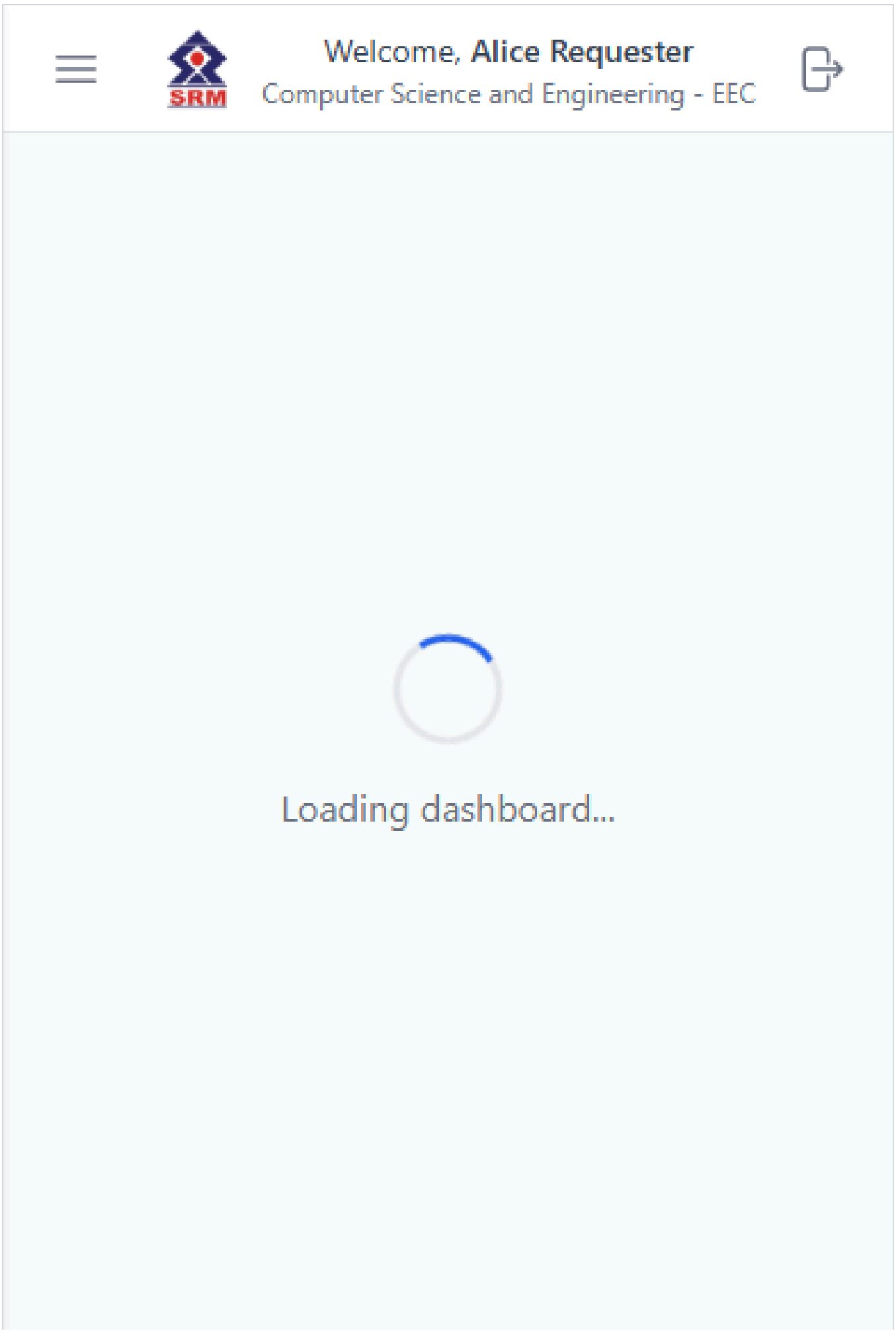
MISC-01 My Profile shows the signed-in user's details — PASS



MISC-05 Head of Institution user management lists users — PASS



MISC-09 mobile viewport collapses navigation into a drawer — PASS


Welcome, Alice Requester
Computer Science and Engineering - EEC
Loading dashboard...

6. Scope & limitations

- Tested the committed code on `main` plus the fix above; any later uncommitted UI work is not covered.
- Not covered: outgoing e-mail delivery (stubbed), SOP AI search / OCR, Excel-to-PDF conversion, the later approval stages (Accountant → Chairman) through the UI, policy approval flow, and non-Chromium browsers.
- Run against an isolated environment, so production-only configuration (nginx, TLS, real SMTP, real data volumes) is not verified; a post-deploy smoke check is recommended.

7. How to re-run

Requires Docker (test DB: `docker compose -f backend/docker-compose.test.yml up -d`).
Backend: `cd backend && ..\.venv\Scripts\python -m pytest`
Browser: `cd frontend && npm ci && npx playwright install chromium && npm run test:e2e`